

Sri Lanka Institute of Information Technology



IE2062 - WEB Security **Assignment** **Bug Bounty Report**

D.M.H.W Dissanayake

IT23711082

Y2S2.WE.CS.01



Table of Contents

1.Security Misconfigurations	4
1. Executive Summary	4
2. Methodology	4
a) Tools Utilized	4
b) Finding	4
Vulnerability Title	4
Vulnerability Description	4
Affected Components	5
Impact Assessment	5
Reproduce	6
Proof of Concept (PoC).....	8
Proposed Mitigation or Fix	9
3. Conclusions and Reflections	9
2. Unauthenticated Access to Sensitive Configuration File	10
1.Executive Summary	10
2.Methodology	10
a. Tools Utilized	10
b. Finding	10
Vulnerability Title	10
Vulnerability Description	10
Vulnerability Description	11
Severity Rating	11
Proof of Concept (PoC).....	11
Impact Assessment	14
Remediation	14
3.Conclusions and Reflections.....	14
3. Reflected XSS	15
1. Executive Summary	15
2.Methodology	15
a) Tools Utilized	15
b) Finding	15
Vulnerability Title	15



Vulnerability Description	15
Vulnerability Discovery	16
Severity Rating	16
Proof of Concept (PoC).....	16
Exploitation.....	17
Impact Assessment	17
Remediation	18
3.Conclusions and Reflections.....	18
4. Web Application Security Misconfigurations.....	20
1.Executive Summary	20
2.Methodology	20
a. Tools Utilized	20
b. Findings.....	20
1. Vulnerability Title	20
Description	20
Vulnerability Discovery	21
Severity Rating	21
Exploitation.....	21
Impact Assessment	21
Remediation	21
2.Vulnerability Title	21
Description	21
Vulnerability Discovery	21
Severity Rating	21
Exploitation.....	22
Impact Assessment	22
Remediation	22
3.Vulnerability Title	22
Description	22
Vulnerability Discovery	22
Severity Rating	22
Exploitation.....	22
Impact Assessment	22



Remediation	22
4.Vulnerability Title	23
Description	23
Vulnerability Discovery	23
Severity Rating	23
Exploitation.....	23
Impact Assessment	23
Remediation	23
5.Vulnerability Title	24
Description	24
Vulnerability Discovery	24
Severity Rating	24
Exploitation.....	24
Impact Assessment	24
Remediation	24
6.Vulnerability Title	24
Description	24
Vulnerability Discovery	24
Severity Rating	25
Exploitation.....	25
Impact Assessment	25
Remediation	25
7.Vulnerability Title	25
Description	25
Vulnerability Discovery	25
Severity Rating	25
Exploitation.....	25
Impact Assessment	25
Remediation	25
Proof of Concept (PoC).....	26
3.Conclusions and Reflections.....	31



1.Security Misconfigurations

1. Executive Summary

This assessment identified multiple security misconfigurations on the target banfield.us, primarily missing security headers and the potential exposure of sensitive backup files. The findings indicate a moderate to high risk if exploited. This report documents the methodology, findings, impact, and remediation steps.

2. Methodology

a) Tools Utilized

- nslookup - to gather DNS and IP details
- ping - to verify host reachability
- Nikto - for web server scanning and vulnerability detection
- curl - to manually verify missing headers

b) Finding

Vulnerability Title

"Missing Security Headers and Potential Exposure of Sensitive Backup Files on banfield.us"

Vulnerability Description

The Nikto scan of <https://banfield.us/> revealed two primary security issues:

1. Missing HTTP Security Headers:

- The server does not implement X-Frame-Options, Strict-Transport Security (HSTS), or X-Content-Type-Options headers. This exposes the site to risks such as clickjacking, TLS downgrade attacks, and MIME-type misinterpretation.



2. Potential Backup File Exposure:

- Multiple files (e.g., /backup.tar, /database. SQL, /banfield.us.pem) return HTTP 200 OK responses, suggesting they may be accessible. If these contain sensitive data like database dumps, certificates, or source code, they could lead to severe data breaches.

Affected Components

- Target URL: <https://banfield.us/>
- IP Address: 172.64.154.103 (primary IP from scan)
- Server: Cloudflare (identified via Nikto output: Server: Cloudflare)
- Components: Web server configuration, file system permissions

Impact Assessment

- **Missing Headers:**
 - Clickjacking (No X-Frame-Options): Attackers could iframe the site, tricking users into actions like submitting forms or clicking malicious links.
 - TLS Downgrade (No HSTS): Without HSTS, users might be redirected to HTTP, exposing traffic to interception. Severity: Low to Medium
- **Backup Files:**
 - If files like /database. SQL or /banfield.us.pem are downloadable and contain sensitive data (e.g., SQL dumps, private keys), attackers could:
 - Access user data
 - Forge certificates
 - Disrupt services
 - Severity: Potentially High

Reproduce

Domain bandfield.us

1. Get Ip details and server details using nslookup

```
kali@kali: ~  
File Actions Edit View Help  
(kali@kali)-[~]  
$ nslookup bandfield.us  
Server:      10.0.2.3  
Address:     10.0.2.3#53  
  
Non-authoritative answer:  
Name:   bandfield.us  
Address: 104.18.33.153  
Name:   bandfield.us  
Address: 172.64.154.103  
Name:   bandfield.us  
Address: 2606:4700:4400::6812:2199  
Name:   bandfield.us  
Address: 2606:4700:440b::ac40:9a67
```

2. Ping Ip address to check it reachable

```
(kali@kali)-[~]  
$ ping 104.18.33.153  
PING 104.18.33.153 (104.18.33.153) 56(84) bytes of data.  
64 bytes from 104.18.33.153: icmp_seq=1 ttl=255 time=11.7 ms  
64 bytes from 104.18.33.153: icmp_seq=2 ttl=255 time=14.0 ms  
64 bytes from 104.18.33.153: icmp_seq=3 ttl=255 time=12.3 ms  
64 bytes from 104.18.33.153: icmp_seq=4 ttl=255 time=7.70 ms  
64 bytes from 104.18.33.153: icmp_seq=5 ttl=255 time=9.07 ms  
64 bytes from 104.18.33.153: icmp_seq=6 ttl=255 time=19.5 ms  
64 bytes from 104.18.33.153: icmp_seq=7 ttl=255 time=15.9 ms  
64 bytes from 104.18.33.153: icmp_seq=8 ttl=255 time=12.5 ms  
64 bytes from 104.18.33.153: icmp_seq=9 ttl=255 time=11.8 ms  
64 bytes from 104.18.33.153: icmp_seq=10 ttl=255 time=8.50 ms  
64 bytes from 104.18.33.153: icmp_seq=11 ttl=255 time=29.3 ms  
64 bytes from 104.18.33.153: icmp_seq=12 ttl=255 time=28.3 ms
```

- Next start scan using Nikto and use V to get all details of scanning

It can't provide all screenshots it violates guidelines of mars.com

```
(kali@kali)-[~]
$ nikto -h https://bandfield.us -Display V
- Nikto v2.5.0

V:Thu Oct 2 02:12:52 2025 - Initialising plugin nikto_fileops
V:Thu Oct 2 02:12:52 2025 - Loaded "File Operations" plugin.
V:Thu Oct 2 02:12:52 2025 - Initialising plugin nikto_dictionary_attack
V:Thu Oct 2 02:12:52 2025 - Loaded "Dictionary attack" plugin.
V:Thu Oct 2 02:12:52 2025 - Initialising plugin nikto_cookies
V:Thu Oct 2 02:12:52 2025 - Loaded "HTTP Cookie Internal IP" plugin.
V:Thu Oct 2 02:12:52 2025 - Initialising plugin nikto_tests
V:Thu Oct 2 02:12:52 2025 - Loaded "Nikto Tests" plugin.
V:Thu Oct 2 02:12:52 2025 - Initialising plugin nikto_shellshock
V:Thu Oct 2 02:12:52 2025 - Loaded "shellshock" plugin.
V:Thu Oct 2 02:12:52 2025 - Initialising plugin nikto_siebel
V:Thu Oct 2 02:12:52 2025 - Loaded "Siebel Checks" plugin.
V:Thu Oct 2 02:12:52 2025 - Initialising plugin nikto_domino
V:Thu Oct 2 02:12:52 2025 - Loaded "IBM/Lotus Domino Specific Tests" plugin.
V:Thu Oct 2 02:12:52 2025 - Initialising plugin nikto_ssl
V:Thu Oct 2 02:12:52 2025 - Loaded "SSL and cert checks" plugin.
V:Thu Oct 2 02:12:52 2025 - Initialising plugin nikto_report_text
V:Thu Oct 2 02:12:52 2025 - Loaded "Text reports" plugin.
V:Thu Oct 2 02:12:52 2025 - Initialising plugin nikto_apacheusers
V:Thu Oct 2 02:12:52 2025 - Loaded "Apache Users" plugin.
```

- Missing Headers:

```
(kali@kali)-[~]
$ curl -I https://banfield.us

HTTP/2 200
date: Thu, 02 Oct 2025 06:16:21 GMT
content-type: text/html
content-length: 7387
cf-ray: 9882120b3a9d513a-CMB
pragma: no-cache
server: cloudflare
```

In scan results

```
+ Server: cloudflare
V:Wed Oct 1 08:57:27 2025 - 200 for GET: /
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The site uses TLS and the Strict-Transport-Security HTTP header is not defined. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
```

This is have missing headers issue

Backup Files:

HTTP 200 OK indicates potential accessibility

```
(kali@kali)-[~]  
$ curl -I https://banfield.us  
  
HTTP/2 200  
date: Thu, 02 Oct 2025 06:16:21 GMT  
content-type: text/html  
content-length: 7387  
cf-ray: 9882120b3a9d513a-CMB  
pragma: no-cache  
server: cloudflare
```

Proof of Concept (PoC)

- Headers:
 - curl -I <https://banfield.us>

```
(kali@kali)-[~]  
$ curl -I https://banfield.us  
  
HTTP/2 200  
date: Thu, 02 Oct 2025 06:16:21 GMT  
content-type: text/html  
content-length: 7387  
cf-ray: 9882120b3a9d513a-CMB  
pragma: no-cache  
server: cloudflare
```

No X-Frame-Options, Strict-Transport-Security, or X-Content-Type-Options present.



Proposed Mitigation or Fix

1. Headers:

- Add security headers via server configuration

2. Backup Files:

- Restrict Access: Move sensitive files out of the web root or use .htaccess
- Fix False Positives: If Cloudflare returns 200 OK for non-existent files, configure proper 404 responses or WAF rules to block such paths.
- Verify: Remove or secure files like /database.sql, /banfield.us.pem (**this /database.sql, /banfield.us.pem get from scan results**)

3. Conclusions and Reflections

- **Lessons Learned:** This process demonstrated how automated tools and manual verification complement each other in identifying security misconfigurations.
- **Challenges Faced:** Limited access to screenshots due to guidelines restricted evidence presentation.



2. Unauthenticated Access to Sensitive Configuration File

1.Executive Summary

An assessment of docuflow.stg.inspectorio.com revealed an unauthenticated access vulnerability exposing a sensitive configuration file (/config.json). This file contained API endpoints, authentication, URLs, and integration keys, which could aid attackers in reconnaissance, service abuse, and potential SSRF attacks. The issue was rated High (CVSS 7.5). Immediate remediation is recommended to protect sensitive data and prevent exploitation.

2.Methodology

a. Tools Utilized

- nslookup - to gather DNS and IP details
- ping - to verify host reachability
- Nikto - for web server scanning and vulnerability detection
- curl - to manually verify missing headers

b. Finding

Vulnerability Title

" Unauthenticated Access to /config.json"

Vulnerability Description

The /config. json endpoint was publicly accessible without requiring authentication. It contained sensitive information such as API endpoints, authentication servers, Sentry DSN, and Zendesk keys. Exposure of this file increases the risk of reconnaissance, service abuse, and advanced attacks like SSRF.



Vulnerability Description

- Used nslookup to verify the target domain.
- Conducted nmap -sV scan to enumerate open ports and services.
- Used curl to access /config.json endpoint directly.
- Verified that no authentication, tokens, or cookies were required for access.

Severity Rating

- High (CVSS 7.5)

Proof of Concept (PoC)

1. Get domain and check details using nslookup

```
(kali㉿kali)-[~]  
$ nslookup docuflow.stg.inspectorio.com  
Server:      10.0.2.3  
Address:     10.0.2.3#53  
  
Non-authoritative answer:  
Name:   docuflow.stg.inspectorio.com  
Address: 104.18.11.44  
Name:   docuflow.stg.inspectorio.com  
Address: 104.18.10.44  
Name:   docuflow.stg.inspectorio.com  
Address: 2606:4700::6812:a2c  
Name:   docuflow.stg.inspectorio.com  
Address: 2606:4700::6812:b2c
```

2. Use Nmap to get all ports and version details using -sV

```
(kali@kali)-[~]
$ nmap -sV 104.18.11.44
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-03 02:20 EDT
Nmap scan report for 104.18.11.44
Host is up (0.017s latency).
Not shown: 993 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
25/tcp    open  smtp?
80/tcp    open  http         Cloudflare http proxy
443/tcp    open  ssl/https    18.11.44
2000/tcp   open  cisco-sccp?
5060/tcp   open  sip?
8080/tcp   open  http         Cloudflare http proxy
8443/tcp   open  ssl/https-alt Cloudflare http proxy
```

3. Again, try to get all details

```
(kali@kali)-[~]
$ nmap -sV -sC -A -p 80,443,8080,8443, 104.18.11.44
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-02 06:43 EDT
Nmap scan report for 104.18.11.44
Host is up (0.014s latency).

PORT      STATE SERVICE      VERSION
80/tcp    open  http         Cloudflare http proxy
|_http-title: Site doesn't have a title (text/plain; charset=UTF-8).
|_http-server-header: cloudflare
443/tcp    open  ssl/https    cloudflare
|_http-title: 400 The plain HTTP request was sent to HTTPS port
|_http-server-header: cloudflare
8080/tcp   open  http         Cloudflare http proxy
|_http-title: Site doesn't have a title (text/plain; charset=UTF-8).
|_http-server-header: cloudflare
8443/tcp   open  ssl/https-alt cloudflare
|_http-server-header: cloudflare
|_http-title: 400 The plain HTTP request was sent to HTTPS port
Warning: OSScan results may be unreliable because we could not find at least 1 open and
1 closed port
Device type: bridge|VoIP adapter|general purpose
Running (JUST GUESSING): Oracle Virtualbox (98%), Slirp (98%), AT&T embedded (95%), QEMU (94%)
OS CPE: cpe:/o:oracle:virtualbox cpe:/a:danny_gasparovski:slirp cpe:/a:qemu:qemu
Aggressive OS guesses: Oracle Virtualbox Slirp NAT bridge (98%), AT&T BGW210 voice gateway (95%), QEMU user mode network gateway (94%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

TRACEROUTE (using port 80/tcp)
HOP RTT ADDRESS
1 3.91 ms 104.18.11.44

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 32.23 seconds
```

4. 1. Open a Terminal: Use Kali Linux or any system with curl installed.
2. Send a GET Request: Execute the following command to access the configuration file:

Command: - curl https://docuflow.stg.inspectorio.com/config.json --insecure



```
(kali@kali)-[~]
$ curl https://docuflow.stg.inspectorio.com/config.json --insecure
{
  "version": "1",
  "docuflowApiPath": "/api",
  "authApiPath": "https://id.stg.inspectorio.com",
  "authApiPlatformPath": "https://id-stg.inspectorio-platform.com",
  "editorHost": "https://collabora.stg.inspectorio.com",
  "sentryDSN": "https://e31ce9ebef8f4af1848296e27393aba4@o126572.ingest.us.sentry.io/4505567025037327",
  "environment": "stg",
  "buildVersion": "map[valueFrom:map[fieldRef:map[fieldPath:metadata.labels['helm.sh/chart']]]]",
  "riseAuthRedirectionLink": "https://rise.stg.inspectorio.com/auth/sso",
  "zendeskKey": "71b0356f-30c3-4c6b-a470-ca47b74bbdd7",
  "isRebrandingFeatureEnabled": true,
  "isAdaChatBotFeatureEnabled": true
}
```

- **Observe the Response:** The server returns a JSON file containing sensitive data.
- **Capture Headers (Optional):** To confirm server details,

run: `curl -I https://docuflow.stg.inspectorio.com/config.json --insecure`

Verify No Authentication: Note that no credentials, cookies, or tokens are required for access.

```
(kali@kali)-[~]
$ curl -I https://docuflow.stg.inspectorio.com/config.json --insecure
HTTP/2 200
date: Thu, 02 Oct 2025 11:18:32 GMT
content-type: application/json
content-length: 682
cf-ray: 9883ccb49a75ff8d-SIN
last-modified: Wed, 01 Oct 2025 19:45:24 GMT
etag: "68dd84d4-2aa"
accept-ranges: bytes
cf-cache-status: DYNAMIC
content-security-policy: default-src 'self'; connect-src 'self' *.clarity.ms find.userpilot.io *.stg.inspectorio.com rollout.ada.support static.ada.support wss://analytex-us.userpilot.io zendesk-eu.my.sentry.io browser-http-intake.logs.datadoghq.com; font-src cdn01.boxcdn.net fonts.gstatic.com; form-action collabora.stg.inspectorio.com; frame-src collabora.stg.inspectorio.com inspectorio.ada.support inspectorio.zendesk.com inspectoriodocuflow.zendesk.com zendesk-sso.inspectorio.com; img-src 'self' data: blob: c.clarity.ms; script-src 'self' 'unsafe-eval'; script-src-elem 'self' 'unsafe-inline' js.userpilot.io static.ada.support; style-src-attr 'unsafe-inline'; style-src-elem 'self' 'unsafe-inline' fonts.googleapis.com; report-uri https://o126572.ingest.us.sentry.io/api/4505567025037327/security/?sentry_key=43aadbb34cae467993050e932ec1b02d6sentry_environment=stg; report-to csp-endpoint
report-to: {"endpoints":[{"url":"https://o126572.ingest.us.sentry.io/api/4505567025037327/security/?sentry_key=43aadbb34cae467993050e932ec1b02d\u0026sentry_environment=stg"}],"group":"csp-endpoint","max_age":3600}
server: cloudflare
```



Impact Assessment

This vulnerability has significant implications:

- **Reconnaissance:** Exposed API endpoints (e.g., /api, https://id.stg.inspectorio.com) reveal the application's structure, aiding targeted attacks like SSRF.
- **Service Abuse:** The Sentry DSN (e31ce9ebef8f4af1848296e27393aba4) and Zendesk key (71b0356f-30c3-4c6b-a470-ca47b74bbdd7) could be misused to log fake errors or access support systems.
- **SSRF Potential:** External URLs (e.g., https://collabora.stg.inspectorio.com) could be leveraged for SSRF if the app processes user-supplied URLs.
Staging Risk: The "environment": "stg" flag indicates a less-secure staging setup, increasing exploitation likelihood.
- **Staging Risk:** The "environment": "stg" flag indicates a less-secure staging setup, increasing exploitation likelihood.

Remediation

- Restrict /Config.Json access behind authentication (API tokens, session validation).
- Remove sensitive keys from publicly accessible files; use server-side environment variables.
- Limit endpoint access to whitelisted IPs where feasible.
- Conduct an audit to ensure no other sensitive files are publicly exposed.

3. Conclusions and Reflections

- **What I Learned:** This assessment highlighted the importance of verifying file exposure risks beyond typical web vulnerability. Sensitive files like configuration data can serve as stepping stones for more severe attacks.
- **Challenges Faced:** Limitations included inability to share screenshots due to disclosure guidelines, which made the documentation process harder.



3. Reflected XSS

1. Executive Summary

During an authorized assessment of <http://banfield.us/search>, a reflected Cross-Site Scripting (XSS) vulnerability was identified in the q parameter. The application reflects unsensitized user input directly in the response, allowing arbitrary JavaScript to execute in a victim's browser. A benign proof-of-concept (PoC)-alert(1)-was used to confirm execution. This vulnerability enables an attacker to perform actions such as session hijacking, phishing redirects, or arbitrary script execution. The issue is classified as Medium–High severity and requires prompt remediation to prevent user compromise.

2. Methodology

a) Tools Utilized

- Nslookup - to gather DNS and IP details
- ping - to verify host reachability
- Nikto - for web server scanning and vulnerability detection
- curl - to manually verify missing headers

b) Finding

Vulnerability Title

Reflected Cross-Site Scripting (XSS) in q parameter

Vulnerability Description

The search endpoint <http://banfield.us/search> accepts a query parameter q and reflects it into the page output without proper sanitization or output encoding. When specially crafted input containing HTML/JavaScript is supplied, the browser executes the payload within the context of the vulnerable site.



Vulnerability Discovery

- Conducted network reconnaissance using Nmap to confirm services and reachable host (HTTP on port 80).
- Navigated to the search endpoint and observed the page behavior when providing search terms.
- Injected a simple script payload into the q parameter via the URL and observed script execution in the browser.
- Verified the reflected input was present in the response HTML using browser DevTools and curl.

Severity Rating

Estimated Severity: Medium — High

Rationale: The vulnerability allows arbitrary JavaScript execution in victims' browsers. The actual impact depends on factors such as whether sensitive cookies are marked **HTTP Only**, presence of a Content Security Policy (CSP), and the nature of user privileges. If session cookies or other sensitive tokens are accessible, the impact increases to High.

Proof of Concept (PoC)

Performed an Nmap scan on banfield.us (IP 172.64.154.103) to identify attack surfaces, as permitted by the program scope

```
(kali@kali)-[~]
$ nmap 172.64.154.103
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-04 04:26 EDT
Nmap scan report for 172.64.154.103
Host is up (0.017s latency).
Not shown: 993 filtered tcp ports (no-response)
PORT      STATE SERVICE
25/tcp    open  smtp
80/tcp    open  http
443/tcp   open  https
2000/tcp  open  cisco-sccp
5060/tcp  open  sip
8080/tcp  open  http-proxy
8443/tcp  open  https-alt

Nmap done: 1 IP address (1 host up) scanned in 11.44 seconds
```



- Identified port 80 (HTTP) as hosting a web service and navigated to <http://banfield.us:80/search>.
- Entered the payload `<script>alert(1)</script>` into the q parameter:
 - URL: `http://banfield.us/search?q=<script>alert(1)</script>`
- Observed an alert box in the browser, confirming the XSS vulnerability.

Can't add those things to this report it contradictory Mars.com program guidelines

Screenshot:-

5. Do not reveal the problem to others until it has been resolved. We ask that you refrain from disclosing this issue to third-parties or the public while we work toward resolution because disclosure may increase the potential risks associated with the vulnerability.

An attacker could exploit this to execute arbitrary scripts, potentially stealing session cookies, redirecting users, or delivering malware to visitors of banfield.us.

Exploitation

An attacker can craft a malicious URL containing arbitrary JavaScript and send it to victims (e.g., via email, social media, or embedded links). When victims open the link:

- The malicious script runs in the victim's browser under the site origin.
- Possible attacker actions include session cookie theft (if cookies are accessible), DOM manipulation, performing actions on behalf of the user, or redirecting users to phishing pages.

Impact Assessment

- **User session compromise:** If authentication cookies are accessible to JavaScript, attackers can hijack sessions.
- **Phishing and social engineering:** Users may be redirected to attacker pages or shown convincing fake UI overlays.
- **Reputation and trust:** Execution of malicious scripts on the site can damage user trust and the organization's reputation.
- **Potential for chained attacks:** Reflected XSS can be used as an initial access vector for more complex attacks (e.g., CSRF amplification, malware delivery).



Remediation

Implement the following technical mitigations:

1. **Output Encoding:** Apply context-appropriate output encoding when reflecting user input into HTML. For example, HTML-encode user input before insertion into page content.
2. **Input Validation:** Employ strict server-side input validation and whitelist acceptable characters/patterns for the q parameter (e.g., alphanumerics and spaces only where appropriate).
3. **Use Framework Escaping:** Use built-in templating or framework escaping functions to ensure user data is not rendered as active HTML/JS.
4. **Content Security Policy (CSP):** Implement a strong CSP that disallows inline scripts ('unsafe-inline') and restricts script sources to trusted origins.
5. **HTTP Only Cookies:** Ensure authentication cookies are set with the HttpOnly flag so JavaScript cannot access them.
6. **HTTPS Enforcement:** Serve site over HTTPS and redirect HTTP requests to HTTPS to prevent certain network-level manipulations.
7. **Output Context Awareness:** If user input must be included within JavaScript, attributes, or URLs, apply the correct encoding for that context.

Suggested quick fix (example for Apache with a templating layer):

- Escape output in the template rendering engine: `{{ q | escape }}`
- Or, at the web server level, validate and reject queries that contain < or > characters.

3. Conclusions and Reflections

What I learned from the process

- Automated discovery (Nmap) combined with manual testing (browser, DevTools) quickly identifies reflected XSS issues.
- Simple PoCs are effective for demonstrating the vulnerability while remaining non-destructive.
- The presence of XSS often indicates broader input/output handling weaknesses that may affect other parameters or endpoints.



Challenges faced

- Disclosure constraints prevented capturing and embedding screenshots or full interactive evidence in this report.
- Determining the full impact requires additional contextual information (cookie attributes, CSP headers, user roles) that was outside the non-destructive testing scope.



4. Web Application Security Misconfigurations

1.Executive Summary

During this penetration testing exercise, we scanned personal.trexcloud.com using Nmap, Nikto, OpenSSL, and Amass. Several security vulnerabilities were identified. These vulnerabilities may lead to session hijacking, clickjacking, information disclosure, and weak cipher usage risks. This report presents those vulnerabilities along with recommended remediation steps.

URL: <https://personal.trexcloud.com/>

2.Methodology

a. Tools Utilized

- **Nmap** - For SSL cipher enumeration
- **Nikto** - For web application vulnerability scanning
- **OpenSSL** - For TLS/SSL testing
- **Amass** - For subdomain enumeration

b. Findings

1. Vulnerability Title

“Missing Secure and Http Only Flags on Cookies”

Description

Certain cookies on the website (like sid, xids) are missing the **Secure** and **HttpOnly** flags. This makes them vulnerable to **session hijacking** or **cross-site scripting (XSS) attacks**, allowing attackers to steal user session data.



Vulnerability Discovery

The vulnerability was discovered by executing the web application vulnerability scanner **Nikto** against the target URL (<https://personal.trexcloud.com>). The scan output explicitly identified several cookies - specifically sid, xids, autolaunch_triggered, and activate_ca_modal_triggered - as being created without the **Secure** flag and the **HttpOnly** flag.

Severity Rating

High

Exploitation

An attacker could exploit XSS vulnerabilities to capture browser cookies and hijack sessions.

Impact Assessment

Unauthorized access to user accounts and data theft.

Remediation

Set cookies with Secure; HTTP Only; Same Site=Strict flags.

2.Vulnerability Title

“Missing X-Frame-Options Header”

Description

Absence of the X-Frame-Options header in HTTP responses enables clickjacking attacks.

Vulnerability Discovery

Discovery was made using the **Nikto** web application scanner. The scan results contained a warning that explicitly stated: "The anti-clickjacking **X-Frame-Options** header is not present".

Severity Rating

Medium



Exploitation

An attacker can create a clickjacking attack to trick users into performing unintended actions.

Impact Assessment

Unauthorized execution of sensitive user actions.

Remediation

Add X-Frame-Options: SAMEORIGIN to HTTP response headers.

3.Vulnerability Title

“Missing X-Content-Type-Options Header”

Description

Absence of the X-Content-Type-Options header allows MIME sniffing attacks.

Vulnerability Discovery

The absence of this security header was confirmed via the Nikto scanner. The output reported that "The X-Content-Type-Options header is not set" on the application.

Severity Rating

Low–Medium

Exploitation

An attacker could execute malicious content by exploiting MIME sniffing.

Impact Assessment

Risk of unauthorized browser content execution.

Remediation

Add X-Content-Type-Options: nosniff to HTTP response headers



4.Vulnerability Title

“Weak Cipher Suites Enabled (RSA Key Exchange)”

Description

Enabling RSA-based cipher suites (TLS_RSA_*) without forward secrecy allows past traffic decryption.

Vulnerability Discovery

This finding was confirmed through an **Nmap** script scan (ssl-enum-ciphers) targeting port 443 of the application's IP address (76.223.84.52). The Nmap scan results listed multiple enabled cipher suites that utilize **RSA** for key exchange, such as TLS_RSA_WITH_AES_128_GCM_SHA256 (rsa 2048) and TLS_RSA_WITH_AES_256_GCM_SHA384 (rsa 2048). The presence of these ciphers indicates a lack of mandatory Forward Secrecy.

Severity Rating

Medium

Exploitation

If the private key is compromised, past traffic could be decrypted.

Impact Assessment

Sensitive data leakage.

Remediation

Configure the server to enable forward secrecy cipher suites (ECDHE_RSA) only.



5.Vulnerability Title

“CORS Misconfiguration”

Description

An Access-Control-Allow-Origin: * header allows unauthorized access to sensitive resources.

Vulnerability Discovery

The misconfiguration was identified by running the **Nikto** scanner. The scan results revealed the presence of the header: "Retrieved **access-control-allow-origin: ***". The wildcard (*) value allows any domain to request resources, indicating a potentially dangerous CORS policy.

Severity Rating

Medium

Exploitation

An attacker could exploit cross-origin requests to exfiltrate sensitive data.

Impact Assessment

Data exposure to unauthorized origins.

Remediation

Restrict Access-Control-Allow-Origin to required domains only.

6.Vulnerability Title

“Subdomain Enumeration Exposure”

Description

Numerous publicly available subdomains increase the attack surface.

Vulnerability Discovery

The large attack surface was discovered by performing domain reconnaissance using the **Amass** tool with the command **amass enum -d trexcloud.com**. The resulting output identified and listed numerous publicly available subdomains and associated CNAME records, such as qa-test4.trexcloud.com, authtest.trexcloud.com, and oinmanager.trexcloud.com.



Severity Rating

Informational → Medium

Exploitation

Attackers could use subdomain information for phishing or reconnaissance attacks.

Impact Assessment

Information disclosure and targeted attacks.

Remediation

Minimize public subdomain enumeration by securing DNS configuration.

7.Vulnerability Title

“Server Banner Disclosure”

Description

Revealing server software details aids attackers during reconnaissance.

Vulnerability Discovery

Nikto scan results showed the server banner disclosure.

Severity Rating

Low

Exploitation

Attackers could target known vulnerabilities of specific server software versions.

Impact Assessment

Simplifies attack planning.

Remediation

Mask server headers.

Proof of Concept (PoC)

```
(kali@kali)-[~]
$ amass enum -d trexcloud.com -o amass_all.txt
trexcloud.com (FQDN) → ns_record → ns-1717.awsdns-22.co.uk (FQDN)
trexcloud.com (FQDN) → ns_record → ns-cloud-e1.googledomains.com (FQDN)
trexcloud.com (FQDN) → ns_record → ns-150.awsdns-18.com (FQDN)
trexcloud.com (FQDN) → ns_record → ns-1534.awsdns-63.org (FQDN)
trexcloud.com (FQDN) → ns_record → ns-cloud-e2.googledomains.com (FQDN)
trexcloud.com (FQDN) → ns_record → ns-620.awsdns-13.net (FQDN)
trexcloud.com (FQDN) → ns_record → ns-cloud-e4.googledomains.com (FQDN)
trexcloud.com (FQDN) → ns_record → ns-cloud-e3.googledomains.com (FQDN)
qa-test4.trexcloud.com (FQDN) → cname_record → tc1-crtrs.tng.trexcloud.com (FQDN)
authtest.trexcloud.com (FQDN) → cname_record → tc1-crtrs.tng.trexcloud.com (FQDN)
okta-dev-parent.trexcloud.com (FQDN) → cname_record → tc1-crtrs.tng.trexcloud.com (FQDN)
oinmanager.trexcloud.com (FQDN) → cname_record → tc-isv-portal-1381344007.us-east-1.elb.amazonaws.com (FQDN)
idx-custom-tc2.trexcloud.com (FQDN) → cname_record → tc2-crtrs.tng.trexcloud.com (FQDN)
tmo.trexcloud.com (FQDN) → cname_record → tc1-crtrs.tng.trexcloud.com (FQDN)
lwdawson.trexcloud.com (FQDN) → cname_record → tc1-crtrs.tng.trexcloud.com (FQDN)
google.trexcloud.com (FQDN) → cname_record → tc1-crtrs.tng.trexcloud.com (FQDN)
shen-admin.trexcloud.com (FQDN) → cname_record → tc1-crtrs.tng.trexcloud.com (FQDN)
cce.trexcloud.com (FQDN) → cname_record → tc1-crtrs.tng.trexcloud.com (FQDN)
qa-directories-adsso1-tc1.trexcloud.com (FQDN) → cname_record → tc1-crtrs.tng.trexcloud.com (FQDN)
drapp.qa-qchen-cox-idp-tc1.trexcloud.com (FQDN) → cname_record → tc1-dr-custom-crtrs.trexcloud.com (FQDN)
jjohnson.trexcloud.com (FQDN) → cname_record → tc1-crtrs.tng.trexcloud.com (FQDN)
whitelist.trexcloud.com (FQDN) → cname_record → tc1-crtrs.tng.trexcloud.com (FQDN)
tc2-custom-crtrs.oktaedge.trexcloud.com (FQDN) → cname_record → tc2-custom-domains-ga-a4aaa032283666d1c.tng.trexcloud.com (FQDN)
```



```
(kali㉿kali)-[~]
$ nikto -h https://personal.trexcloud.com -output nikto_personal.txt

- Nikto v2.5.0

+ Multiple IPs found: 76.223.84.52, 13.248.200.14
+ Target IP: 76.223.84.52
+ Target Hostname: personal.trexcloud.com
+ Target Port: 443

+ SSL Info: Subject: /C=US/ST=California/L=San Francisco/O=Okta, Inc./CN=*.trexcloud.com
Ciphers: ECDHE-RSA-AES128-GCM-SHA256
Issuer: /C=US/O=DigiCert Inc/CN=DigiCert Global G2 TLS RSA SHA256 2020 CA1
+ Start Time: 2025-10-08 12:58:38 (GMT-4)

+ Server: nginx
+ /: Cookie sid created without the secure flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /: Cookie sid created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /: Cookie xids created without the secure flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /: Cookie xids created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /: Cookie autolaunch_triggered created without the secure flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /: Cookie autolaunch_triggered created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /: Cookie activate_ca_modal_triggered created without the secure flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
```



```
per.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /: Cookie activate_ca_modal_triggered created without the secure flag. See: https://d
eveloper.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /: Cookie activate_ca_modal_triggered created without the httponly flag. See: https:/
/developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://develope
r.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: Uncommon header 'accept-ch' found, with contents: Sec-CH-UA-Platform-Version.
+ /: Uncommon header 'x-okta-request-id' found, with contents: f4f0075839e38f38a15b3dca
72cd5a58.
+ Root page / redirects to: https://personal.trexcloud.com/app/UserHome?iss=https%3A%2F
%2Fpersonal.trexcloud.com&session_hint=AUTHENTICATED
+ : Server banner changed from 'nginx' to 'awselb/2.0'.
+ /app/: The X-Content-Type-Options header is not set. This could allow the user agent
to render the content of the site in a different fashion to the MIME type. See: https:/
/www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-head
er/
+ /E14Yqlua.htaccess: Cookie t created without the secure flag. See: https://developer.
mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /E14Yqlua.htaccess: Cookie t created without the httponly flag. See: https://develope
r.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /E14Yqlua.gif: Retrieved access-control-allow-origin header: *.
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /robots.txt: contains 6 entries which should be manually viewed. See: https://develope
r.mozilla.org/en-US/docs/Glossary/Robots.txt
+ Server is using a wildcard certificate: *.trexcloud.com. See: https://en.wikipedia.or
g/wiki/Wildcard_certificate
+ ERROR: Error limit (20) reached for host, giving up. Last error: opening stream: can'
t connect: : Invalid argument
+ Scan terminated: 19 error(s) and 18 item(s) reported on remote host
+ End Time:                2025-10-09 01:48:17 (GMT-4) (46179 seconds)

+ 1 host(s) tested
```




```
(kali㉿kali)-[~]
$ nmap -p 443 --script ssl-enum-ciphers personal.trexcloud.com -oN nmap_ssl_ciphers.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-08 13:06 EDT
Nmap scan report for personal.trexcloud.com (76.223.84.52)
Host is up (0.0055s latency).
Other addresses for personal.trexcloud.com (not scanned): 13.248.200.14
rDNS record for 76.223.84.52: a266a6be2f07974ad.awsglobalaccelerator.com

PORT      STATE SERVICE
443/tcp   open  https
| ssl-enum-ciphers:
|   TLSv1.2:
|     ciphers:
|       TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (secp256r1) - A
|       TLS_RSA_WITH_AES_128_GCM_SHA256 (rsa 2048) - A
|       TLS_RSA_WITH_AES_128_CBC_SHA256 (rsa 2048) - A
|       TLS_RSA_WITH_AES_128_CBC_SHA (rsa 2048) - A
|       TLS_RSA_WITH_AES_256_GCM_SHA384 (rsa 2048) - A
|       TLS_RSA_WITH_AES_256_CBC_SHA256 (rsa 2048) - A
|       TLS_RSA_WITH_AES_256_CBC_SHA (rsa 2048) - A
|     compressors:
|       NULL
|     cipher preference: server
|_  least strength: A

Nmap done: 1 IP address (1 host up) scanned in 17.83 seconds
```

```
(kali㉿kali)-[~]
$ openssl s_client -connect personal.trexcloud.com:443 -cipher 'AES128-SHA' < /dev/null
Connecting to 76.223.84.52
CONNECTED(00000003)
depth=2 C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert Global Root G2
verify return:1
depth=1 C=US, O=DigiCert Inc, CN=DigiCert Global G2 TLS RSA SHA256 2020 CA1
verify return:1
depth=0 C=US, ST=California, L=San Francisco, O=Okta, Inc., CN=*.trexcloud.com
verify return:1
---
Certificate chain
 0 s:C=US, ST=California, L=San Francisco, O=Okta, Inc., CN=*.trexcloud.com
  i:C=US, O=DigiCert Inc, CN=DigiCert Global G2 TLS RSA SHA256 2020 CA1
  a:PKKEY: rsaEncryption, 2048 (bit); sigalg: RSA-SHA256
  v:NotBefore: Mar  3 00:00:00 2025 GMT; NotAfter: Apr  3 23:59:59 2026 GMT
 1 s:C=US, O=DigiCert Inc, CN=DigiCert Global G2 TLS RSA SHA256 2020 CA1
  i:C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert Global Root G2
  a:PKKEY: rsaEncryption, 2048 (bit); sigalg: RSA-SHA256
  v:NotBefore: Mar 30 00:00:00 2021 GMT; NotAfter: Mar 29 23:59:59 2031 GMT
---
```

```
subject=C=US, ST=California, L=San Francisco, O=Okta, Inc., CN=*.trexcloud.com
issuer=C=US, O=DigiCert Inc, CN=DigiCert Global G2 TLS RSA SHA256 2020 CA1
-----
No client certificate CA names sent
-----
SSL handshake has read 3353 bytes and written 639 bytes
Verification: OK
-----
New, SSLv3, Cipher is AES128-SHA
Protocol: TLSv1.2
Server public key is 2048 bit
Secure Renegotiation IS supported
Compression: NONE
Expansion: NONE
No ALPN negotiated
SSL-Session:
    Protocol    : TLSv1.2
    Cipher      : AES128-SHA
    Session-ID: A7F3AAF4605D8C306C0557ED6F06AFD82F6D016850F1982F1B472304C727CB8A
    Session-ID-ctx:
    Master-Key: BC055843F12361A86F9AA5189A2EC342D69190AC2F5C308BFC0CC9218218F73E83C1A00
```



```

1A65254BBCA963EB02EBB16A5
PSK identity: None
PSK identity hint: None
SRP username: None
TLS session ticket lifetime hint: 86400 (seconds)
TLS session ticket:
0000 - 01 34 a4 f7 1a c2 ae 75-66 83 12 67 75 2c 0d 7c .4.....uf..gu,.|
0010 - ef 62 8d 0c 35 2f 8a e9-8d b9 b6 06 c4 86 4d 0f .b..5/.....M.
0020 - 03 9d ae ac 1b 92 9c 05-da a3 fa 48 f4 c5 80 a8 .....H....
0030 - 2a aa 07 14 d9 49 91 ae-52 5f 67 25 7e 63 1f 5b *....I..R_g%~c.[
0040 - 55 c4 51 fd 02 35 23 db-64 e0 07 8d 01 18 34 be U.Q..5#.d.....4.
0050 - 2b 50 29 f7 a4 a5 85 53-83 b7 87 91 d2 c2 1d 1a +P)....S.....
0060 - 13 97 1d 3e 73 ab b3 fc-5e 23 8f 9c 7a d7 5e 61 ... >s ... ^#..z.^a
0070 - d5 16 1f b5 78 4e 16 f7-ee 76 b8 59 29 a4 09 2e ....xN ... v.Y) ...
0080 - 04 f5 04 57 a9 86 a0 ba-a0 69 ...W.....i

Start Time: 1759943212
Timeout : 7200 (sec)
Verify return code: 0 (ok)
Extended master secret: yes
DONE

```

3. Conclusions and Reflections

1. What you learned:

- **Real-world Applications and Configuration Weaknesses:** The testing process highlighted how real-world applications often have configuration weaknesses, especially regarding server hardening and security header implementation.
- **Missing Security Headers:** A crucial lesson was understanding the defensive value of fundamental security headers like X-Frame-Options and X-Content-Type-Options and how their absence facilitates attacks such as clickjacking and MIME sniffing.
- **Importance of Transport Security:** The exercise reinforced the importance of using only strong, modern cipher suits (such as those offering Forward Secrecy, like ECDHE) and the risks associated with weak cipher usage (like TLS_RSA_*).
- **Manual Validation:** The project emphasized the necessity of using a suite of specialized tools (Nmap, Nikto, Amass) and manually correlating their outputs to build a comprehensive security posture assessment.



2.Challenges faced:

- **Interpreting Automated Scanning Results:** A key challenge was interpreting the output from automated scanning tools like Nikto, which required filtering out noise and irrelevant data to focus on actionable, valid vulnerabilities.
- **Filtering False Positives:** The process involved critically analyzing scan findings to eliminate potential false positives before confirming a vulnerability's existence and accurately rating its severity.
- **Preparing Accurate Remediation Suggestions:** Formulating specific, technical, and realistic remediation suggestions that directly address the vulnerability and guide the development team was a complex but essential part of the process.